Báo cáo Tuần 3

I. Worklog

Thời gian thực hiện: 19/10/2026 – 25/10/2026

Nguyễn Xuân Nhật (MSSV: 24110293) Thời gian: 9h

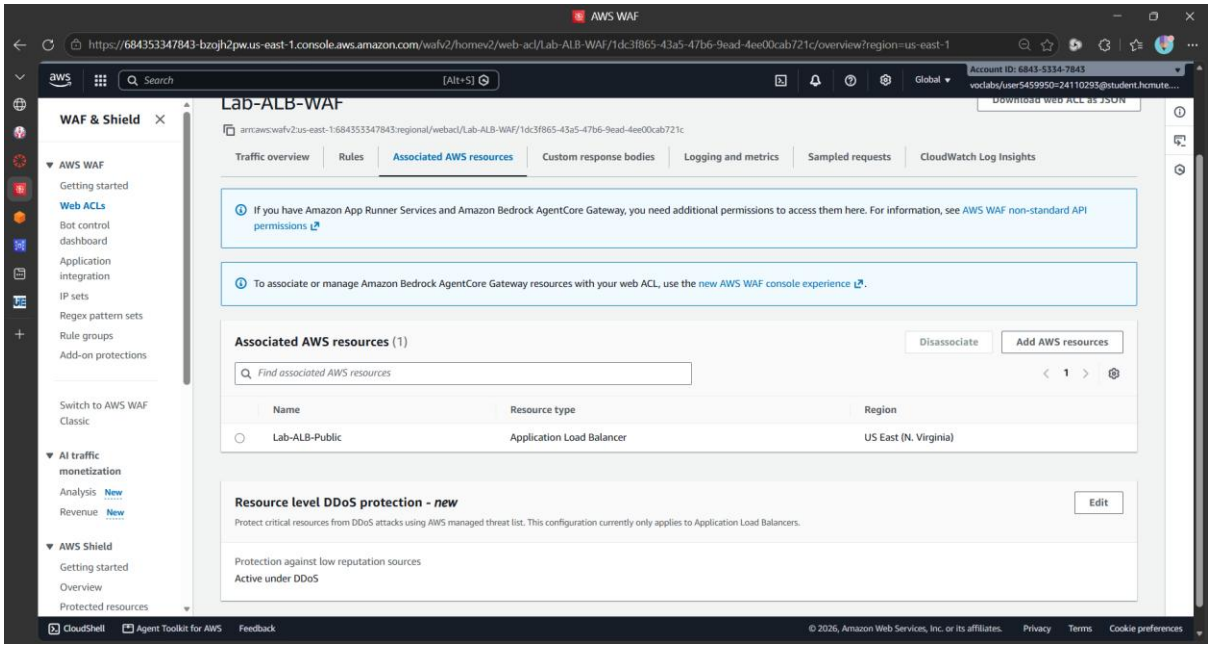
- Khởi tạo và cấu hình AWS WAFv2 Web ACL (Lab-ALB-WAF), liên kết bảo vệ Application Load Balancer (Lab-ALB-Public). (3 giờ)
- Khởi tạo kênh thông báo Amazon SNS Topic (Lab-Security-Alerts-Topic) và xác thực email quản trị viên. (2.5 giờ)
- Thực nghiệm các kịch bản tấn công an ninh (SQL Injection, XSS, HTTP Flood) và ghi nhận nhật ký Sampled Requests. (3.5 giờ)

Nguyễn Công Bình (MSSV: 24110168) Thời gian: 9h

- Kích hoạt dịch vụ Amazon GuardDuty tại Region us-east-1, tạo sample findings và phân tích mối đe dọa. (3 giờ)
- Thiết lập hệ thống giám sát cảnh báo Amazon CloudWatch Alarms cho WAF Blocked Requests và hiệu năng EC2 CPU Utilization. (2.5 giờ)
- Thiết lập các bộ quy tắc chuẩn của AWS (AWSManagedRulesCommonRuleSet, AWSManagedRulesSQLiRuleSet) và tạo custom rule RateLimit-100. (2 giờ)
- Đóng gói mã nguồn kiểm thử tự động hóa, cấu hình CloudFormation template và cập nhật tài liệu Git. (2 giờ)

II. Tích hợp, bảo mật và giám sát CloudWatch

1. Khởi tạo AWS WAFv2 Web ACL và liên kết bảo vệ ALB (Lớp 1 - Edge Security)

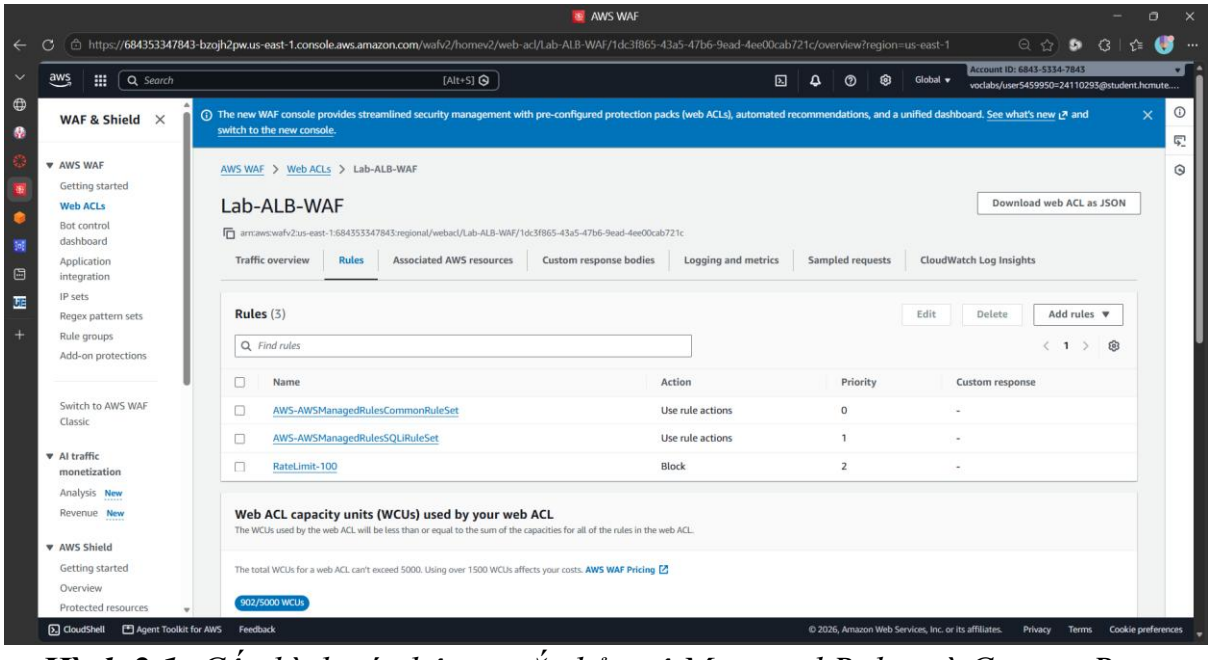


Hình 1.1: *Khởi tạo AWS WAFv2 Web ACL (Lab-ALB-WAF) và liên kết bảo vệ cho Application Load Balancer (Lab-ALB-Public)*

Mục đích:

- Web ACL được triển khai tại tầng biên của hệ thống mạng, gắn trực tiếp vào Load Balancer để đóng vai trò bộ lọc gói tin HTTP/HTTPS trước khi dữ liệu đi vào mạng nội bộ.
- Mọi truy cập vào hệ thống từ Internet đều được giám sát và kiểm tra theo thời gian thực tại lớp bảo vệ Tầng 7

2. Cấu hình các bộ quy tắc bảo vệ (WAF Rules & Rate Limiting)



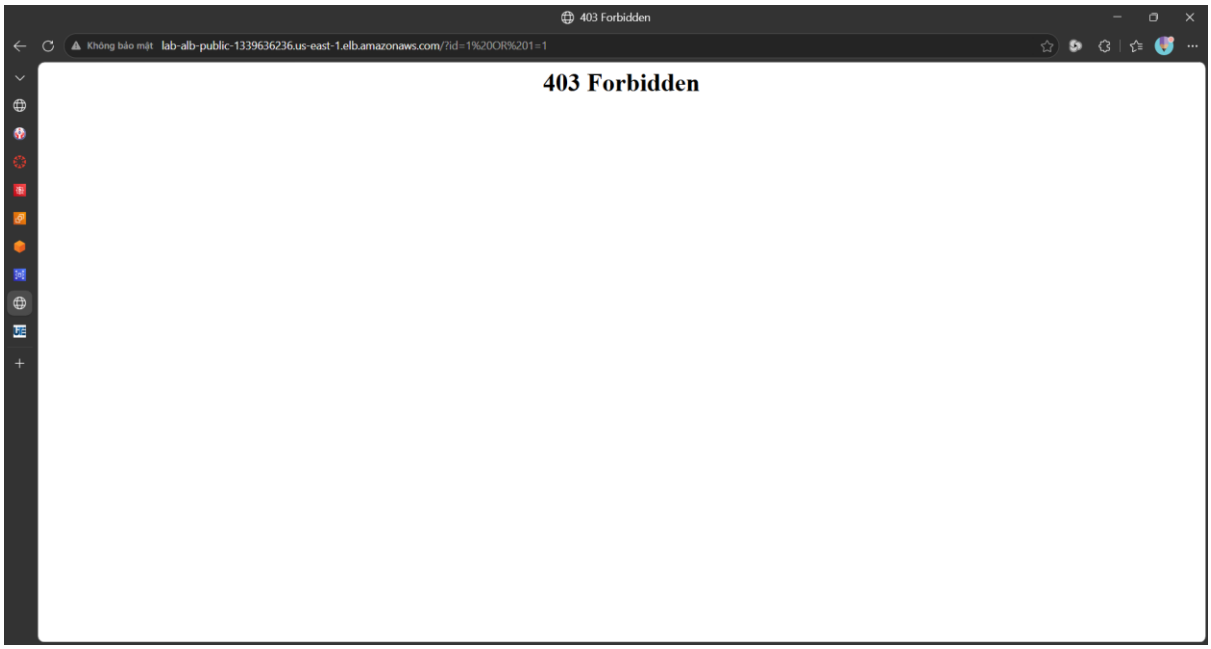
Hình 2.1: *Cấu hình các bộ quy tắc bảo vệ Managed Rules và Custom Rate-based Rule trên Web ACL.*

Nhận xét:

- **AWSManagedRulesCommonRuleSet & AWSManagedRulesSQLiRuleSet:** Tự động nhận diện và chặn đứng các cuộc tấn công khai thác lỗ hổng web phổ biến (OWASP Top 10) và kỹ thuật chèn câu lệnh SQL độc hại.
- **RateLimit-100:** Thiết lập ngưỡng chặn tự động cho bất kỳ IP nào phát sinh vượt quá 100 requests trong vòng 5 phút, giảm thiểu nguy cơ tấn công từ chối dịch vụ (DoS/HTTP Flood) và quét lỗ hổng tự động.

3. Thử nghiệm tấn công và ghi nhận nhật ký

Test Case 1

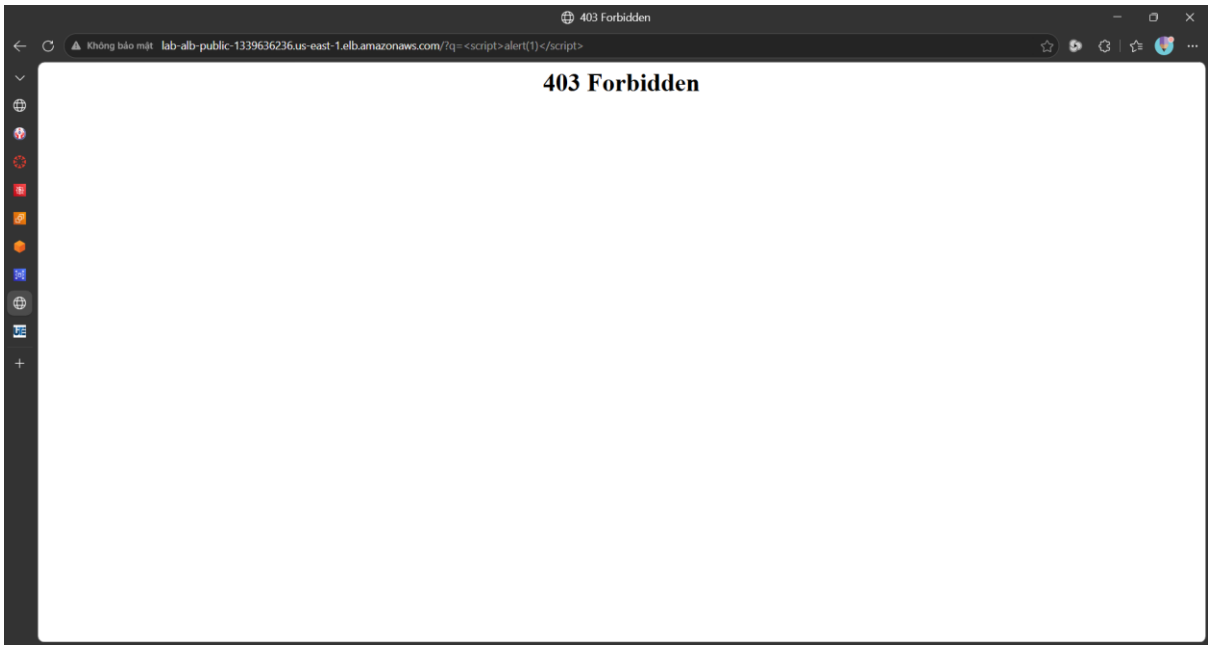


Hình 3.1: *Kiểm thử bảo mật Test Case 1 – AWS WAF ngăn chặn tấn công SQL Injection và trả về phản hồi HTTP 403 Forbidden.*

Nhận xét:

- Yêu cầu chứa ký tự khai thác logic SQL (OR 1=1) trong chuỗi truy vấn (query string) đã kích hoạt mẫu nhận diện (signature) của bộ quy tắc AWSManagedRulesSQLiRuleSet.
- Gói tin bị ngắt kết nối ngay tại tầng Load Balancer, bảo vệ cơ sở dữ liệu backend RDS không bị rò rỉ dữ liệu hoặc vượt qua xác thực ứng dụng.

Test Case 2

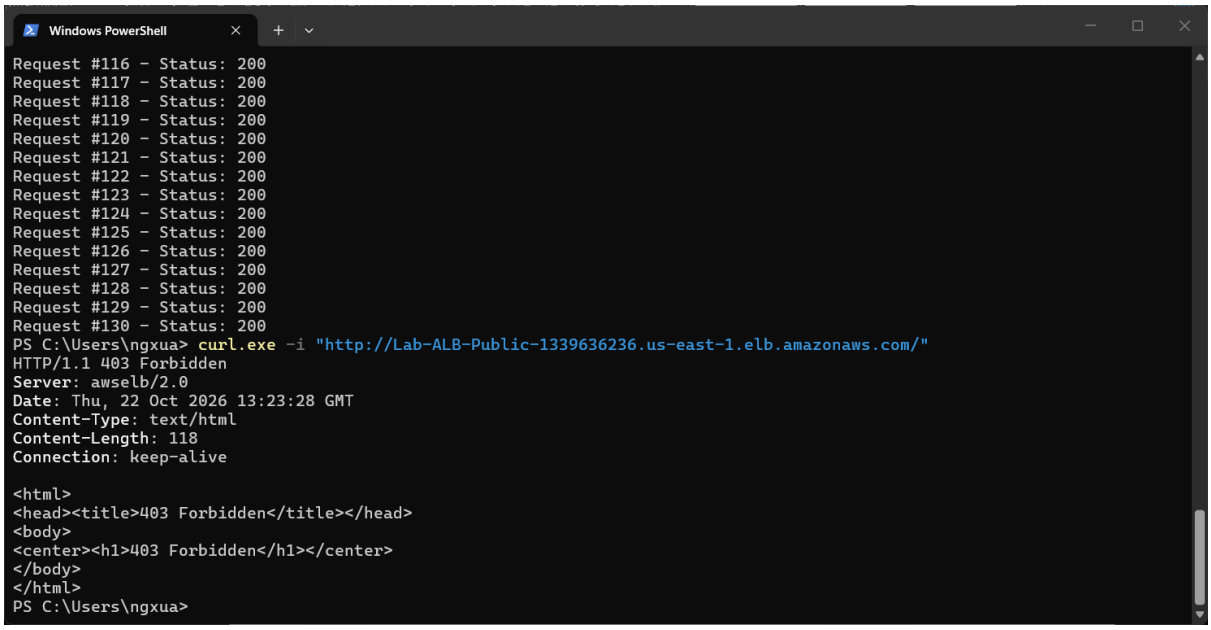


Hình 3.2: *Kiểm thử bảo mật Test Case 2 – AWS WAF ngăn chặn tấn công Cross-Site Scripting (XSS).*

Nhận xét:

- Payload chứa thẻ mã độc <script> thuộc danh mục các mẫu tấn công định nghĩa trong bộ quy tắc bảo vệ cốt lõi AWSManagedRulesCommonRuleSet.
- Cơ chế kiểm soát đã ngăn chặn rủi ro mã độc JavaScript được truyền xuống máy chủ web và thực thi trên trình duyệt của người dùng cuối.

Test Case 3

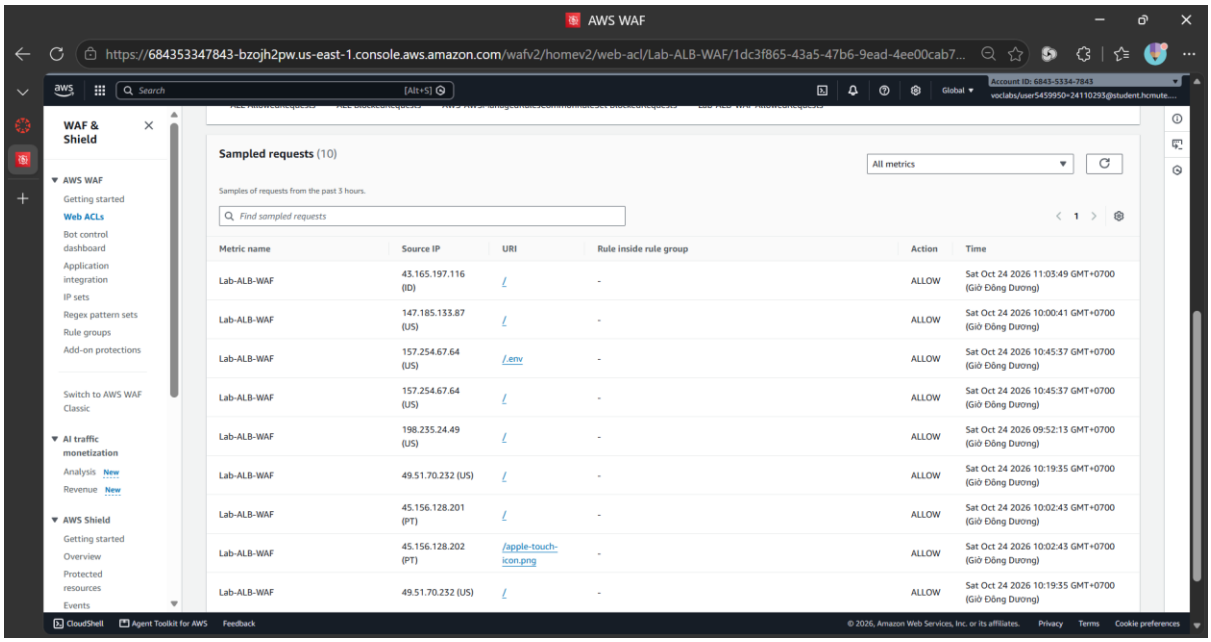


Hình 3.3: *Kiểm thử bảo mật Test Case 3 – Kích hoạt quy tắc Rate Limiting (RateLimit-100) trên AWS WAF và ghi nhận phản hồi chặn HTTP 403 Forbidden.*

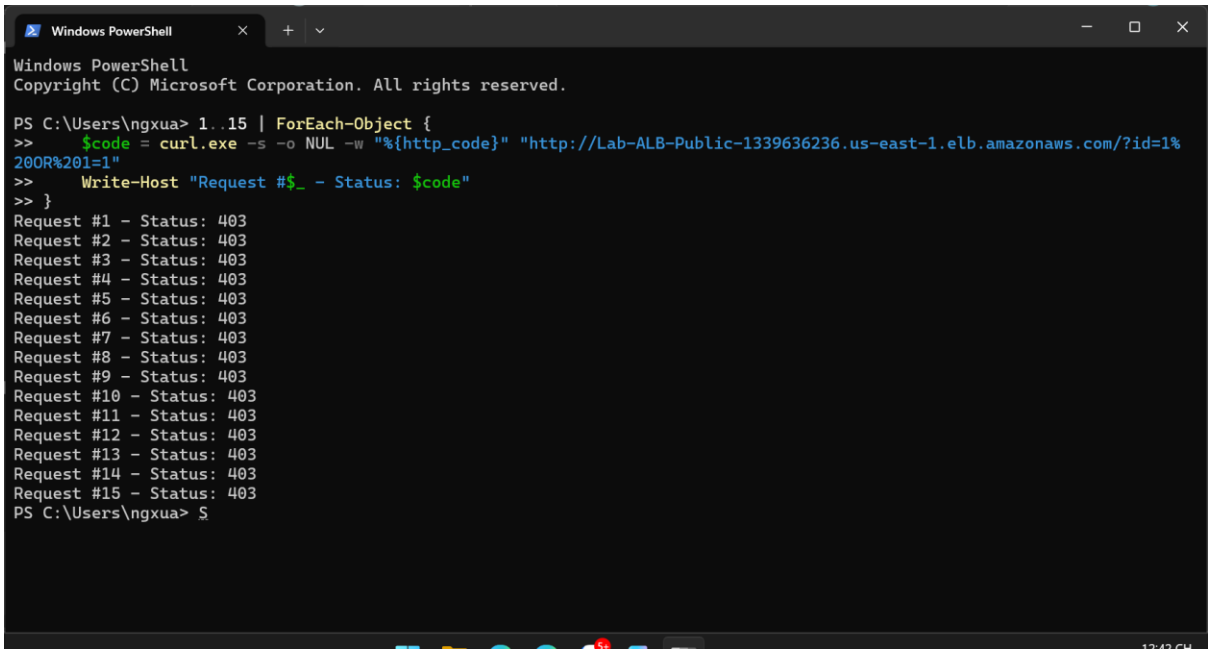
Nhận xét:

- Sau khi gửi dồn dập 130 requests tới DNS của Load Balancer, bộ đếm phân tán của AWS WAF đã ghi nhận tần suất truy cập vượt ngưỡng quy định (100 requests / 5 phút).
- Hệ thống WAF tự động thực thi hành vi Block, đưa địa chỉ IP kiểm thử vào danh sách cách ly tạm thời.
- Lệnh kiểm tra bằng curl ngay sau đó nhận phản hồi HTTP/1.1 403 Forbidden trực tiếp từ tầng biên (Server: awselb/2.0), chứng minh lưu lượng bất thường đã bị triệt tiêu ngay tại Load Balancer mà không làm tiêu hao tài nguyên xử lý của máy chủ web EC2.

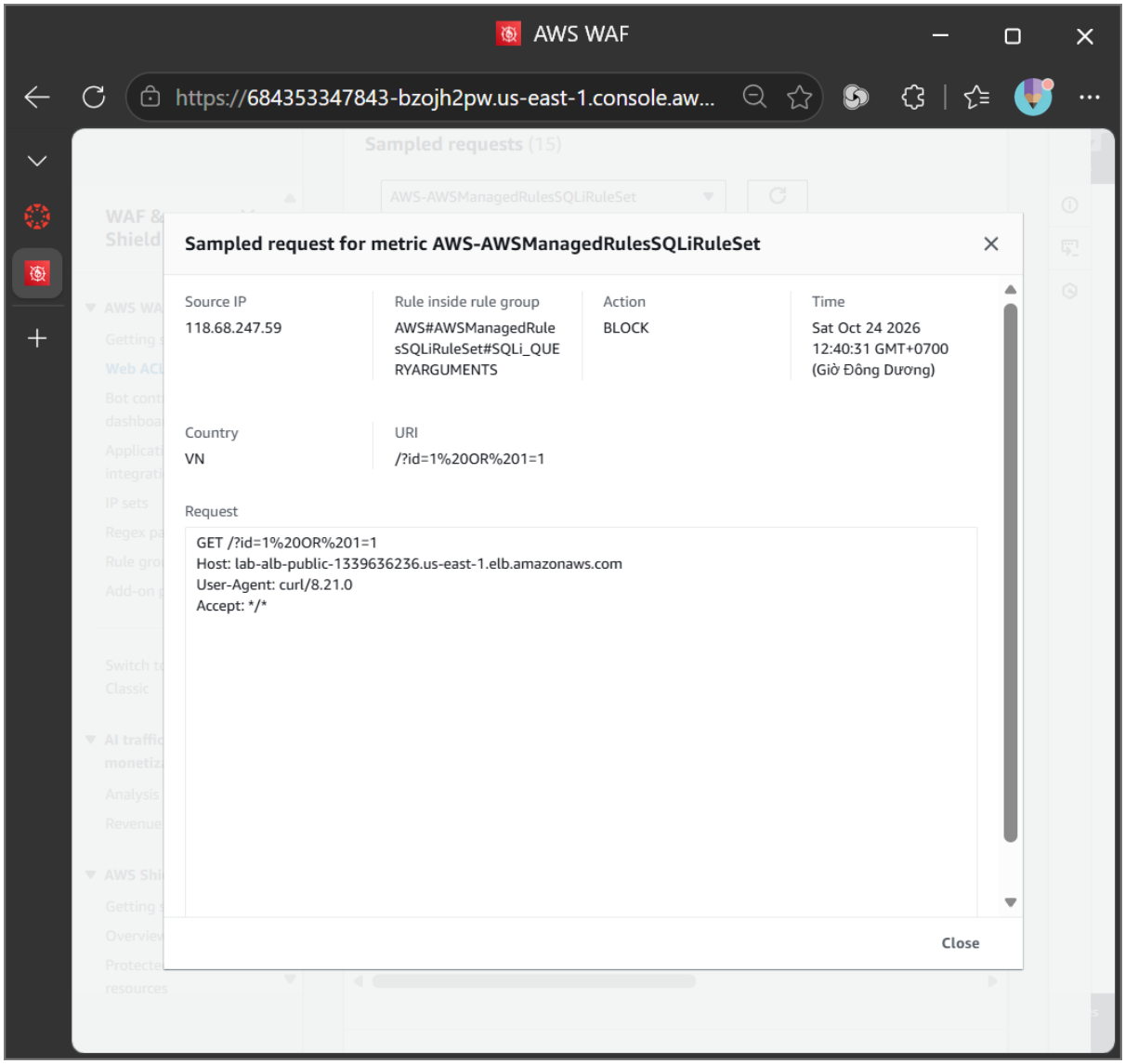
Sample Requests



Hình 3.4: *Nhật ký WAF Sampled Requests trước khi kiểm thử – Toàn bộ lưu lượng truy cập hợp lệ được cấp phép (Action: ALLOW)*

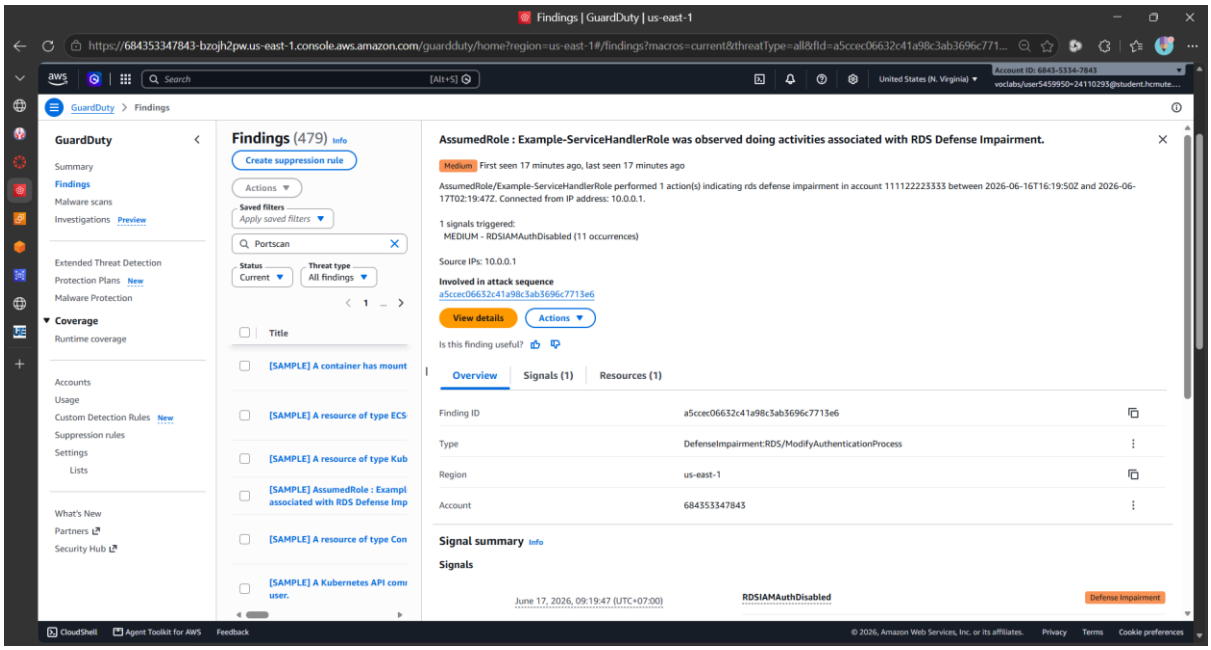


Hình 3.5: *Tấn công SQL Injection*



Hình 3.6: *Nhật ký WAF Sampled Requests sau khi kiểm thử – Gói tin mang payload SQL Injection bị WAF phát hiện và kích hoạt hành động chặn (Action: BLOCK)*

4. Kích hoạt giám sát mối đe dọa thông minh với Amazon GuardDuty

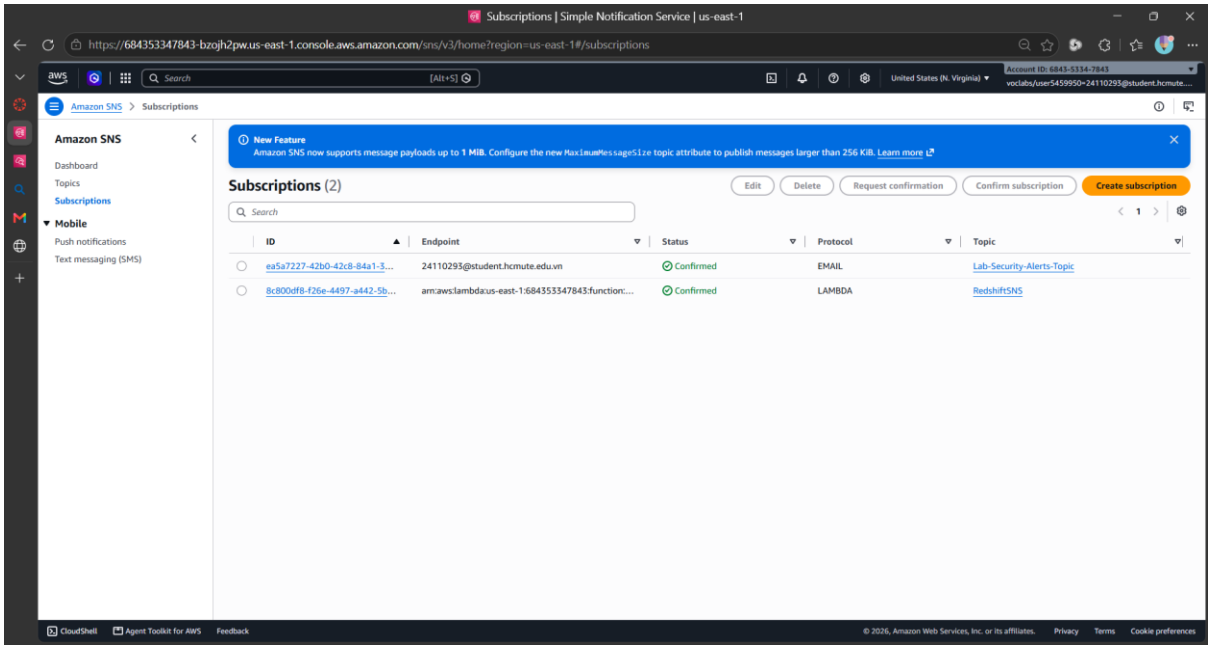


Hình 4.1: *Phân tích chi tiết cảnh báo an ninh tầng cơ sở dữ liệu (DefenseImpairment:RDS/ModifyAuthenticationProcess) trên giao diện Amazon GuardDuty.*

Nhận xét & Đánh giá an ninh:

- Amazon GuardDuty tự động phân tích luồng nhật ký sự kiện CloudTrail và phát hiện hành vi can thiệp trái phép nhằm làm suy yếu cấu hình an ninh của cơ sở dữ liệu RDS (RDSIAMAuthDisabled).
- Cơ chế giám sát liên tục (Continuous Monitoring) giúp phát hiện sớm nguy cơ bị hạ thấp tiêu chuẩn bảo mật (Defense Impairment) ngay từ bước chuẩn bị leo thang đặc quyền, cung cấp đầy đủ thông tin pháp chứng (Finding ID, Source IP, IAM Role) để người quản trị kịp thời thu hồi quyền truy cập và bảo vệ dữ liệu.

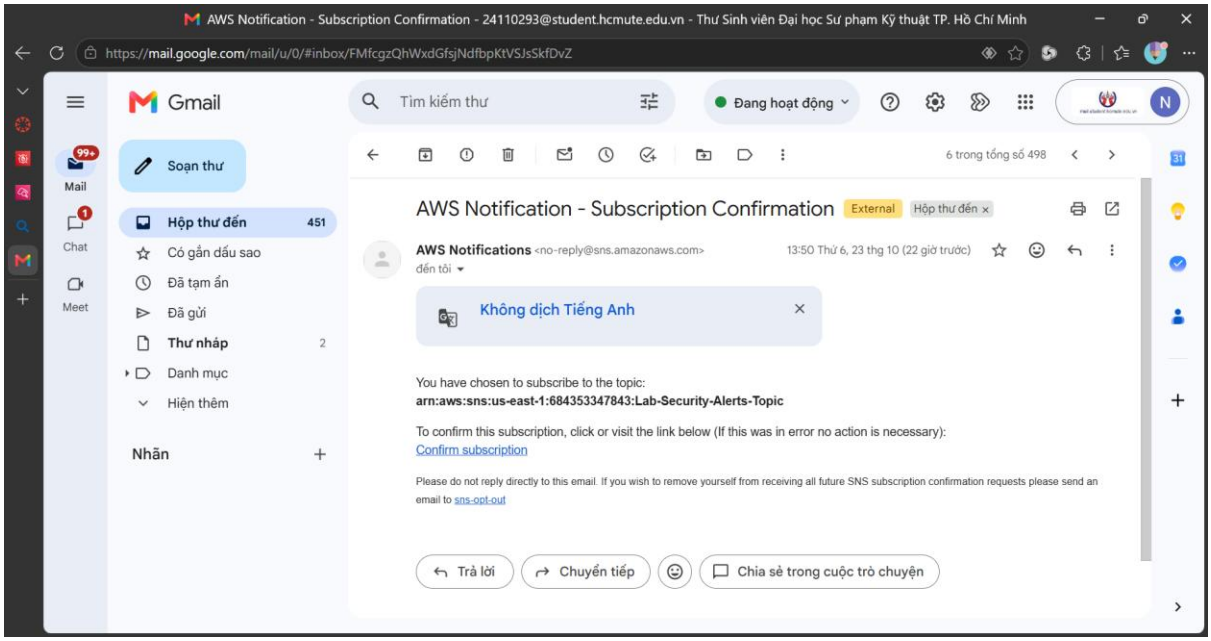
5. Thiết lập hệ thống thông báo sự cố Amazon SNS



Hình 5.1: *Khởi tạo kênh thông báo Amazon SNS (Lab-Security-Alerts-Topic) và xác thực đăng ký nhận cảnh báo qua Email.*

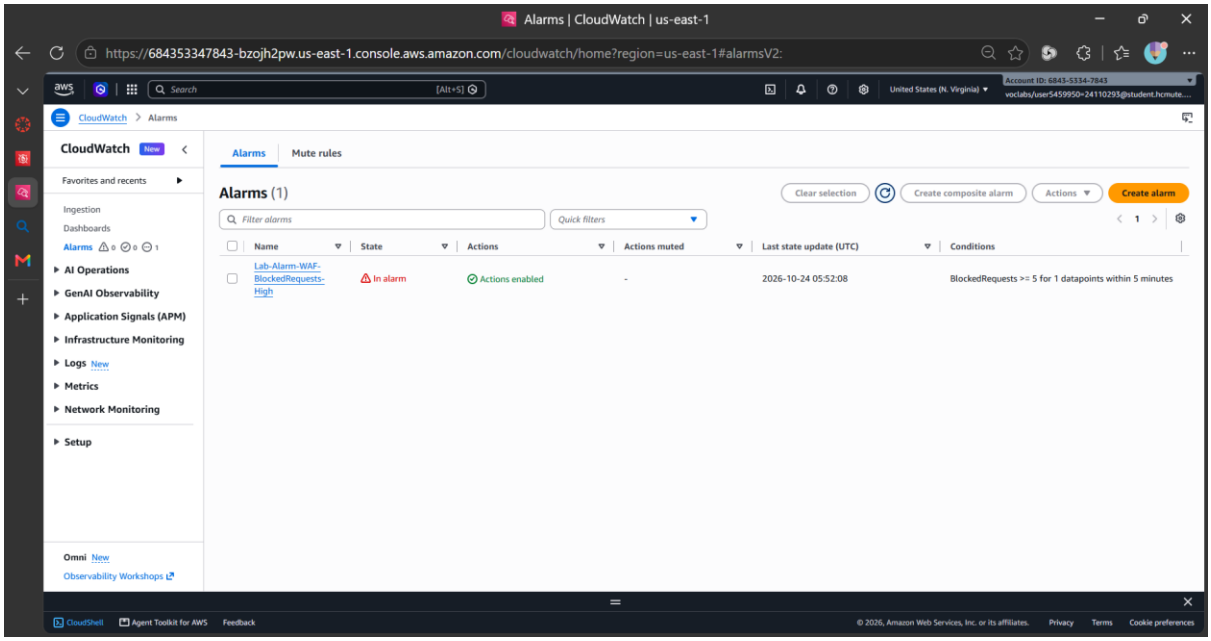
Nhận xét:

- Kênh thông báo đóng vai trò trung tâm phân phối bản tin cảnh báo tự động khi phát hiện các sự cố bất thường từ hệ thống giám sát.
- Trạng thái *Confirmed* đảm bảo đường truyền liên lạc thông suốt tới quản trị viên bảo mật ngay khi có cảnh báo phát sinh từ hạ tầng đám mây.



Hình 5.2: *Bản tin thông báo khẩn cấp từ Amazon SNS gửi về email sinh viên xác nhận sự cố an ninh được phát hiện.*

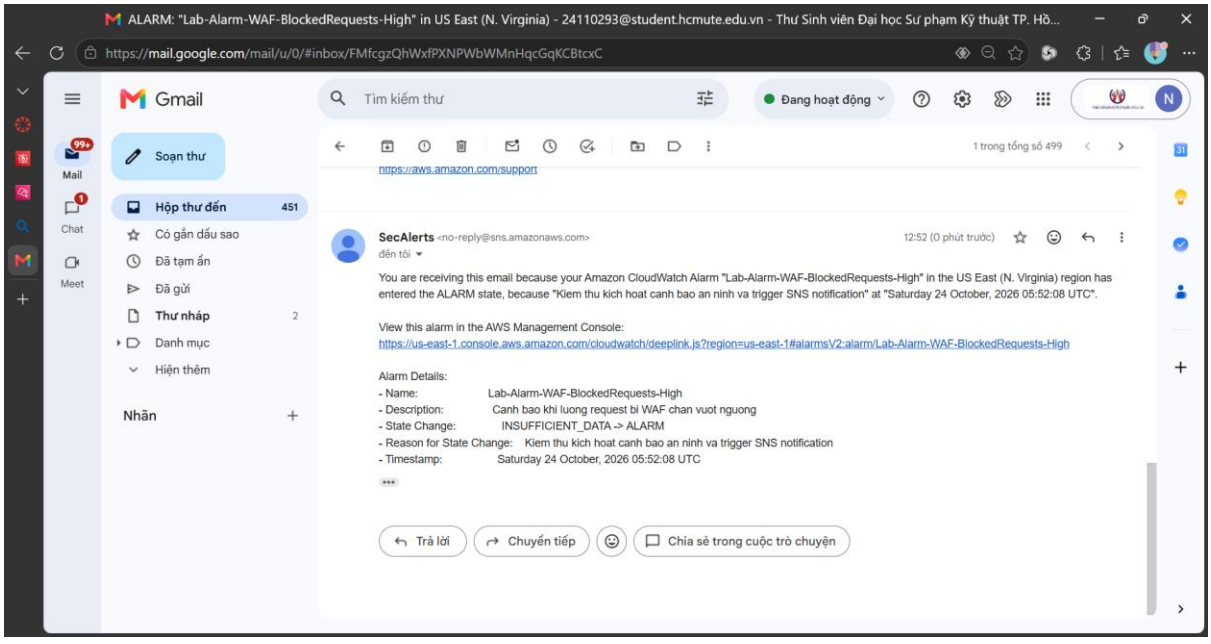
6. Cấu hình giám sát cảnh báo Amazon CloudWatch Alarms



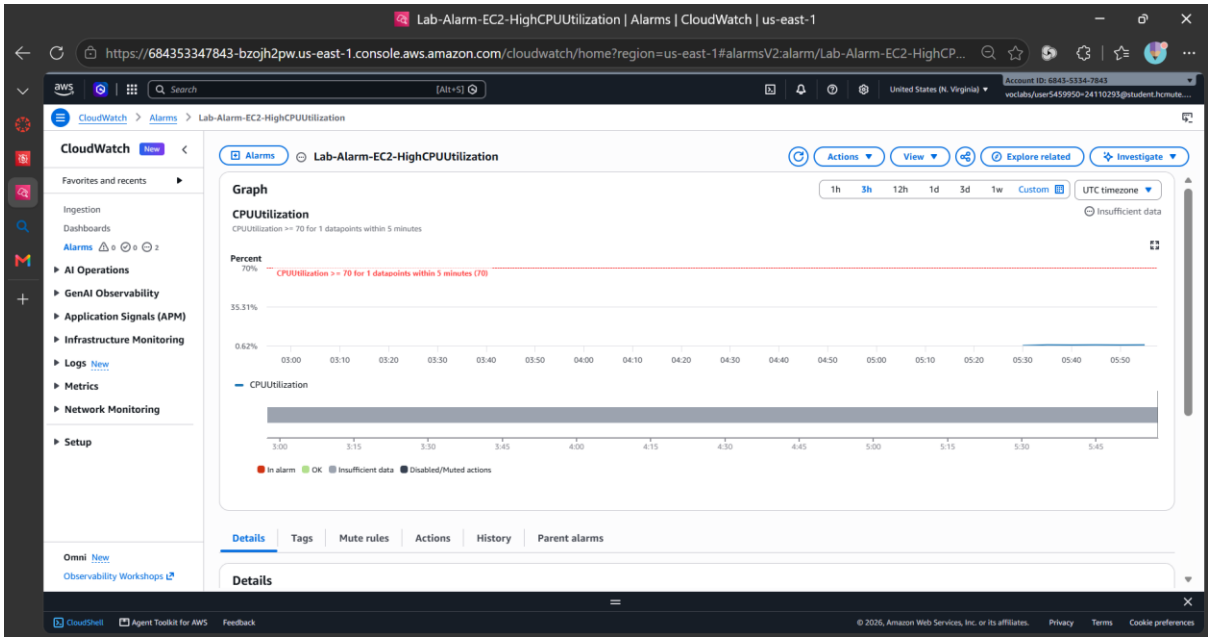
Hình 6.1: *Amazon CloudWatch Alarm chuyển sang trạng thái kích hoạt báo động (In alarm) khi ghi nhận sự kiện vi phạm an ninh.*

Nhận xét:

- Sau khi hệ thống WAF ghi nhận lưu lượng tấn công vượt ngưỡng quy định, CloudWatch Alarm đã tự động chuyển trạng thái đánh giá từ OK sang In alarm.
- Hệ thống kích hoạt hành động liên kết (Alarm Action), gửi tín hiệu cảnh báo khẩn cấp tới kênh truyền tin Amazon SNS Topic Lab-Security-Alerts-Topic



Hình 6.2: *Bản tin cảnh báo sự cố an ninh tự động từ Amazon SNS gửi về hộp thư quản trị viên (24110293@student.hcmute.edu.vn).*



Hình 6.3: *Cấu hình Amazon CloudWatch Alarm (Lab-Alarm-EC2-HighCPUUtilization) tự động giám sát ngưỡng quá tải vi xử lý của máy chủ web.*

7. Mã nguồn IaC

```
AWSTemplateFormatVersion: '2010-09-09'
Description: 'Week 3 - AWS WAFv2 WebACL and CloudWatch Monitoring Infrastructure as Code'

Resources:
  # 1. AWS WAFv2 Regional Web ACL
  LabWebACL:
    Type: AWS::WAFv2::WebACL
    Properties:
      Name: Lab-ALB-WAF
      Scope: REGIONAL
      DefaultAction:
        Allow: {}
      VisibilityConfig:
        SampledRequestsEnabled: true
        CloudWatchMetricsEnabled: true
        MetricName: Lab-ALB-WAF
      Rules:
        - Name: AWS-AWSManagedRulesCommonRuleSet
          Priority: 0
          Statement:
            ManagedRuleGroupStatement:
              VendorName: AWS
              Name: AWSManagedRulesCommonRuleSet
          OverrideAction:
            None: {}
          VisibilityConfig:
            SampledRequestsEnabled: true
            CloudWatchMetricsEnabled: true
            MetricName: AWS-AWSManagedRulesCommonRuleSet
        - Name: AWS-AWSManagedRulesSQLiRuleSet
          Priority: 1
          Statement:
            ManagedRuleGroupStatement:
              VendorName: AWS
              Name: AWSManagedRulesSQLiRuleSet
```

```
        OverrideAction:
          None: {}
        VisibilityConfig:
          SampledRequestsEnabled: true
          CloudWatchMetricsEnabled: true
          MetricName: AWS-AWSManagedRulesSQLiRuleSet
      - Name: RateLimit-100
        Priority: 2
        Action:
          Block: {}
        Statement:
          RateBasedStatement:
            Limit: 100
            AggregateKeyType: IP
        VisibilityConfig:
          SampledRequestsEnabled: true
          CloudWatchMetricsEnabled: true
          MetricName: RateLimit-100

  # 2. CloudWatch Alarm for WAF Blocked Requests
  CloudWatchWAFBlockedAlarm:
    Type: AWS::CloudWatch::Alarm
    Properties:
      AlarmName: Lab-Alarm-WAF-BlockedRequests-High
      MetricName: BlockedRequests
      Namespace: AWS/WAFV2
      Statistic: Sum
      Period: 300
      EvaluationPeriods: 1
      Threshold: 5
      ComparisonOperator: GreaterThanOrEqualToThreshold
      AlarmActions:
        - !Ref SecurityNotificationTopic

  # 3. CloudWatch Alarm for EC2 CPU Utilization
  CloudWatchEC2CPUAlarm:
    Type: AWS::CloudWatch::Alarm
    Properties:
      AlarmName: Lab-Alarm-EC2-HighCPUUtilization
      MetricName: CPUUtilization
      Namespace: AWS/EC2
      Statistic: Average
      Period: 300
      EvaluationPeriods: 1
      Threshold: 70
      ComparisonOperator: GreaterThanOrEqualToThreshold
```

III. GitHub của nhóm

Link github: https://github.com/CongBinh-designer/Bao-mat-da-lop-cho-ung-dung

IV. Kế hoạch tuần 4

Kiểm thử tổng thể hệ thống: Thực hiện chuỗi kịch bản kiểm thử toàn diện từ tầng biên (WAF/ALB) qua tầng ứng dụng (EC2/Secrets Manager) đến tầng dữ liệu (RDS KMS), xác thực lại toàn bộ ma trận đe dọa STRIDE.

Phân tích và tối ưu hóa chi phí : Trích xuất số liệu AWS Billing & Cost Explorer, đánh giá các giải pháp kiến trúc đã giúp tiết kiệm hạn mức.

Xây dựng quy trình và dọn dẹp tài nguyên: Lập kịch bản hủy tài nguyên theo đúng thứ tự phụ thuộc, tránh phát sinh chi phí ngầm sau khi kết thúc dự án.

Hoàn thiện tài liệu báo cáo tổng kết cuối kỳ: Hợp nhất toàn bộ kết quả thực nghiệm 4 tuần, đính kèm đầy đủ minh chứng kỹ thuật, cập nhật kho lưu trữ GitHub.

Quay video Demo: Quay màn hình trực tiếp trình diễn kiến trúc, các kịch bản tấn công/phòng thủ thực tế và cơ chế cảnh báo tự động của hệ thống.